

Signup Consent

A new account now holds its credentials and grants nothing until the Terms of Use and the Privacy Policy are accepted. The first authorized change to the Phase 1 signup flow — and it needed almost none of it. The second commit is not part of that change: CI rejected the first one, and section 5 is the account of what it found.

Branch **claude/create-app-repository-1cxsih**Head **e3ded66**

2 commits · 31 files

Tests **234 passed** · 18 browserOTP suite **26 passed**

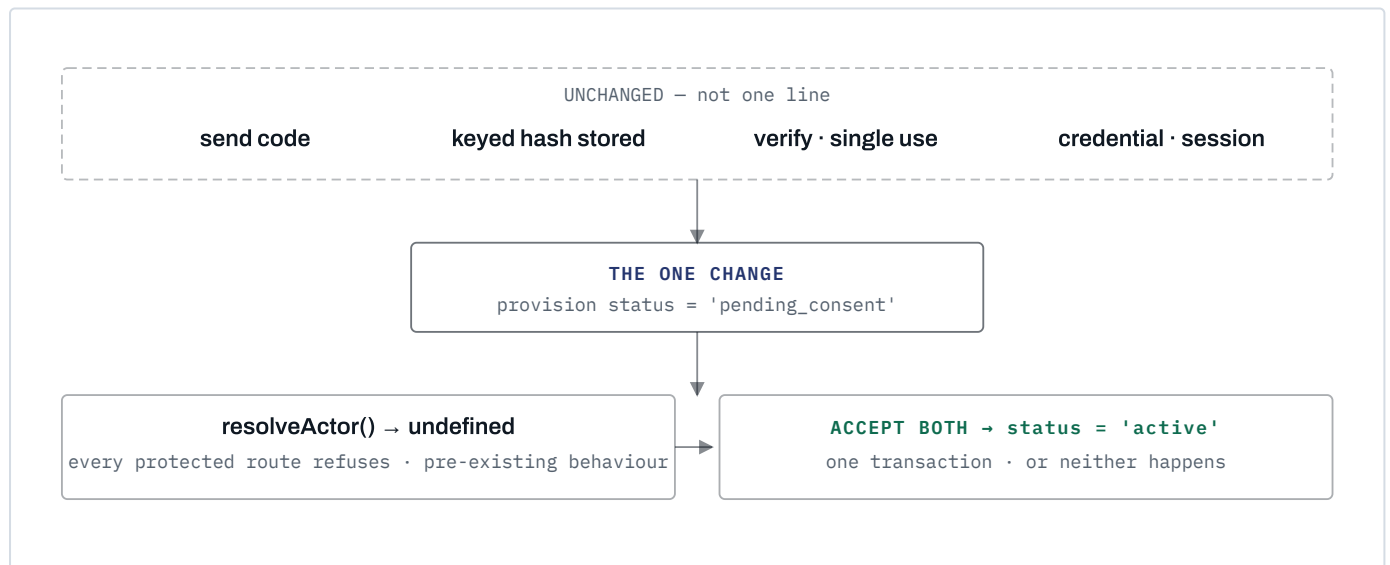
1

Where the gate went, and why it cannot weaken authentication

You asked for this explained before anything else, so it comes first.

THE ENFORCEMENT POINT ALREADY EXISTED

`resolveActor` has always returned **no actor** for any user whose status is not `active` — that is how suspension works, and it predates this milestone by two phases. So the entire gate is one word in the provisioning hook: a new account is created as `pending_consent` instead of `active`.



Everything above the dashed line is the Phase 1 flow, untouched. The gate is not *inside* the OTP path — it is downstream of it, in a door that was already there. That is why the OTP guarantees cannot have been weakened by it: **no code that implements them was edited.**

GUARANTEE YOU NAMED	STATE	EVIDENCE
HMAC-SHA256 storage, no plaintext	UNCHANGED	Asserted again after signup: a 64-hex hash in <code>otp_challenges</code> , nothing in <code>verification</code> .
Better Auth's phone plugin stays uninstalled	UNCHANGED	The removed endpoint still answers 404 , asserted in a browser test.
Rate limits	UNCHANGED	Still 429 with <code>Retry-After</code> . See section 5 for a caveat about the test environment.
Single use and attempt bounds	UNCHANGED	Challenge reads <code>consumed_at</code> is not <code>null</code> after signup; wrong code still 400 and creates no account.
The 23 OTP adversarial tests	UNEDITED, ALL PASSING	<code>phone-otp.test.ts</code> has no diff in this commit.

One thing has to be said plainly, because it shapes everything else: **consent records reference `users.id`**. A consent cannot be recorded before the account row exists. Any design claiming to collect consent strictly *before* account creation is either storing it somewhere else — a parallel system, which you forbade — or describing itself inaccurately.

So the account is created and is *not usable*. Your own wording allowed for this: "created/activated". What a `pending_consent` account can do is nothing:

ATTEMPT	RESULT
GET <code>/api/v1/me</code> , <code>/api/v1/wallet</code>	401 — no actor to resolve
Navigating to <code>/fr/wallet</code>	Redirected to sign-in
Any action behind <code>authorize()</code>	There is no actor to authorize
Accepting the general terms	THE ONE THING IT MAY DO

Why the acceptance endpoint does not require an actor

It deliberately does **not** call `requireActor`. A pending account has no actor *by design* — that is the gate — so an endpoint demanding one would be unreachable by exactly the people who need it. It resolves **identity** from the session instead: a weaker thing, and all this action needs. It grants no capability and can touch no account but the one the session belongs to.

Activation is one transaction, or nothing

```
await db.transaction(async (tx) => {
  accepted = await acceptCurrentVersions(tx, userId, ACCOUNT_CONSENT_KINDS, options, context);
  // Belt and braces: re-ask the gate rather than trusting the loop above.
  await requireConsent(tx, userId, ACCOUNT_CONSENT_KINDS, options);
  // Conditional: accepting terms cannot revive a SUSPENDED account.
  update users set status = 'active' where id = ... and status = 'pending_consent'
});
```

Recording without activating locks someone out of an account they agreed to. Activating without recording is the failure this milestone exists to prevent. Neither is a state that can exist.

The client chooses neither the version nor the locale

Carried forward from milestone 3, and tested again on this path. The acceptance endpoint takes **no body at all**: not a version id, not a locale, not a document list.

ATTACK	TEST
Record an acceptance of a superseded version by hand	Both old versions recorded directly; the gate stays shut and the account stays <code>pending_consent</code> .
Accept the English documents for a French account	A real acceptance of real documents — and not of the ones binding this account. Still refused.
Accept only one of the two	Tested in both directions: terms alone, then privacy alone. Neither activates anything.

And the re-accept case you specified: publishing a new version of either document closes the gate again on the next protected action, with the earlier acceptance preserved rather than overwritten.

The signup step, and why it is not the boundary

The screen names both documents, their exact version, and the locale they are in, and the button stays disabled until the person actually ticks the box. That is the interface doing its job — presenting what is being agreed to, rather than a link and an assumption.

It is not what enforces anything:

BROWSER TEST	PROVES
Verify the OTP, then stop	Account exists, is <code>pending_consent</code> , and both <code>/api/v1/me</code> and <code>/api/v1/wallet</code> answer 401. Nothing accepted.
Navigate to the wallet anyway	Redirected to sign-in. Unreachable by navigation, not only by API.
Delete the consent step from the DOM	The account is exactly as unusable. Status unchanged, 401 unchanged, redirect unchanged.
Accept through the UI	Exactly two records — <code>terms_of_use@0.0.0-placeholder/signup</code> and <code>privacy_policy@...</code> — status <code>active</code> , and <code>/api/v1/me</code> now 200.
Accept through the API instead	Same activation, same two records. One gate, two transports.
Inspect the OTP state after all of it	Keyed hash only, nothing in <code>verification</code> , challenge consumed, old plaintext endpoint still 404.

READ THIS SECTION FIRST

The first commit of this milestone, `ccb2700`, passed everything locally and **failed in CI**: four browser tests, all at the moment a verification code is requested. The milestone's own change was not involved. What the failure exposed was two defects that had been sitting in the repository since Phase 1 — one of them a control the senior review had explicitly asked for and that was **not actually running in the application**.

Both are fixed in `e3ded66`. Neither would have been found by any test that existed, and neither could have been found locally, for the reason immediately below.

Why local was green and CI was red

`next start` sets `NODE_ENV=production` only when it is *not already set* — and `.env` sets it to `development` for the dev server. So every local browser run served the application in **development mode** while CI served it in **production mode**. Two behaviours differ across that line, and both matter here:

- Better Auth enables its own rate limiter **only** under `NODE_ENV=production`. Locally it was off. In CI it was on.
- The session cookie is marked `Secure` only in production — so the suite was not exercising the cookie behaviour its own configuration file claimed it was.

The browser suite now pins `NODE_ENV=production` in the server command. That is the whole fix for the divergence, and it is load-bearing: with the old limiter restored and the pin removed, the same build passes locally; with the pin in place it fails, in exactly the way CI failed.

Defect one — a literal that overrode the reviewed policy

The phone-OTP plugin declared a Better Auth rate rule of **ten requests a minute** on `/phone-otp`. The suite makes fourteen sends from one address, so in CI the eleventh was refused and the remaining tests failed on a 429 that had nothing to do with what they were testing.

THE REAL PROBLEM WAS NOT THE NUMBER

It was that a **literal in code silently overrode stored configuration**. An operator who raised `perIpPerHour` to 200 in `platform_settings` would still have been capped at ten a minute by a number nobody could see, from a limiter that keeps its counters in one process's memory and answers in its own shape — no audit row, and not the `ratelimit.exceeded` contract the rest of the API uses.

The backstop is now derived from the same policy and deliberately set **above** it — twice the hourly allowance, inside one minute. High enough that the refusal a caller actually meets is always the audited PostgreSQL one; low enough that a flood from a single address is still stopped before it reaches the database. `/phone-otp/verify` keeps a tight rule of its own: attempt counts are bounded per challenge by PostgreSQL, but nothing else bounds how fast one address may hammer that endpoint.

Defect two — decision 7 was satisfied in the package and not in production

Chasing the first defect turned up the second. `loadOtpPolicy()` was written, tested and correct. **Nothing called it.** `apps/web` built the auth instance without a policy, so every request used the compiled-in defaults and an operator's `UPDATE` to `platform_settings` changed nothing at all.

HOW A PASSING TEST SUITE MISSED IT

The domain tests called `loadOtpPolicy` *themselves* and asserted it returned the stored row — which it did. The one call that was missing was the one nobody tested: the application's. A test that performs the integration it is meant to be checking will pass on any build, wired or not.

The policy is now a **resolver**, consulted on the request that issues a code rather than once at construction. That distinction is not decoration: the auth instance is built once and cached for the life of the process, so a value resolved at construction would pin whatever the table held at boot and turn "change a limit" back into "deploy". The code's lifetime and attempt bound come from the same read, so `ttlMs` and `verificationAttempts` are configuration now too.

Five tests cover the wiring. Three are domain tests; two are browser tests that change a row in `platform_settings` and then ask the *real* server, over HTTP, for real codes — deliberately end to end, because the defect lived precisely in the gap a unit test cannot see. One of them raises a limit and requires the running process to follow it without a restart.

NOTHING ABOUT THE OTP GUARANTEES MOVED

Codes are still stored only as a keyed HMAC in `otp_challenges.code_hash`; the plaintext path is still absent and still asserted absent; single use, the attempt counter and one-live-challenge are still enforced by PostgreSQL; every verification failure still answers identically. The reviewed limits themselves — 5 per phone per hour, 20 per IP per hour, 60 s cooldown, 5 attempts, 5 min lifetime — are **unchanged**. What changed is that the application now reads them.

The browser environment still raises only the per-IP ceiling in `platform_settings`, the same `UPDATE` an operator would run — and as of this commit that `UPDATE` actually does something.

Mutation evidence — and one that is not caught

DELIBERATE DEFECT	RESULT
Accounts provisioned <code>active</code> again — the gate never engages	8 DOMAIN TESTS and 4 OF 6 BROWSER TESTS
Activation flips the status unconditionally (a suspended account could be revived)	2 TESTS
<code>requireAccountConsent</code> becomes a no-op	5 TESTS
The belt-and-braces re-check inside the activation transaction is dropped	NOT CAUGHT

And four more for the CI fix

DELIBERATE DEFECT	RESULT
The policy resolver is ignored — <code>resolveOtpPolicy</code> always returns the compiled-in defaults	3 DOMAIN TESTS
The <code>apps/web</code> wiring is removed, i.e. the defect exactly as it shipped	BROWSER, ON ITS FIRST ASSERTION
The ten-a-minute literal is restored	REPRODUCES THE CI FAILURE
...and the <code>NODE_ENV</code> pin removed as well	PASSES — WHICH IS THE POINT

WHAT THE LAST TWO ROWS ARE FOR

The third is the diagnosis, executed rather than argued: restoring the literal produces the same five failures, in the same specs, at the same point in the run, and stretches the run to the same 1.4 minutes CI took. The fourth then removes the `NODE_ENV` pin and the identical broken build **passes** — which is the local-green / CI-red divergence, demonstrated rather than asserted.

The first row also found a weak assertion of my own. One new test sent a code and expected the next send to be refused; under the mutation it was refused anyway, by the *cooldown* rather than the limit, so it passed while proving nothing. It now requires the second send to *succeed* — which only a build that reads the stored one-millisecond cooldown can do — before requiring the third to be refused.

TWO THINGS I WANT ON THE RECORD

Three mutations first reported as "not caught" had never actually applied. The edits failed silently against a shell-quoting problem and the suite passed because the code was unchanged. Every mutation above now asserts that the file changed before its result is believed. A mutation that does not apply proves nothing, and reads exactly like a test gap.

The fourth is genuinely uncaught, and I have left it in. The re-check inside the transaction is redundant with the acceptance loop directly above it, so by construction no test can distinguish its presence. It stays as defence against a future change to the acceptance path that silently records less than it should — but nothing proves it works, and this packet is the record of that.

```
pnpm install --frozen-lockfile    exit 0
db reset → migrate → seed        from zero
pnpm lint                         exit 0
pnpm typecheck                   exit 0
pnpm test                        234 passed | 3 skipped (19 files)    was 214 / 18
pnpm build                       exit 0
playwright test                  18 passed                          was 10 · production mode, from
OTP adversarial suite            26 passed — 23 unedited, 3 added for the wiring
ledger concurrency               6 passed
reconcile-check                  clean, zero drift
pnpm audit --audit-level high    No known vulnerabilities found
```

New: **17 domain tests** in `consent/signup.test.ts`, driven through the *real* OTP flow rather than constructed fixtures, and **6 browser tests** in `signup-consent.spec.ts`. The CI fix adds **3 domain tests** and **2 browser tests** for the policy wiring.

WHERE THESE NUMBERS COME FROM

Everything above was run locally on `e3ded66`. The browser line was run against a database **built from zero** and a server pinned to `NODE_ENV=production` — the CI configuration, reproduced deliberately, because a local run that did not match CI is what let `ccb2700` through.

CI, on the same commit: run #16 (32344158087) — **ALL THREE JOBS GREEN**. `dependency scan` 18 s, `lint · typecheck · test` 2 m 09 s, `browser · authorization assertions` 1 m 41 s, including a database rebuilt from zero and the ledger reconciliation check. The previous head, `ccb2700`, was run #15 and **FAILED** — section 5.

31 files

FILE	WHY
core/consent/signup.test.ts	New. 17 tests against the real signup path.
core/consent/index.ts	ACCOUNT_CONSENT_KINDS , activateAccountWithConsent , requireAccountConsent , accountConsentStatus .
core/auth/better-auth.ts	The gate: provision as pending_consent . One word plus its explanation.
core/auth/phone-otp-plugin.ts	Verify reports what is outstanding, so the client can show the right step. Reporting only.
db/migrations/0008 + schema/identity.ts	The new status, and a users_status_valid constraint that did not exist before.
web/api/v1/consent/account/route.ts	New. GET state, POST accept-and-activate.
web/components/SignInForm.tsx	The third step.
web/lib/auth-client.ts	consentRequired from verify; the acceptance call.
web/e2e/signup-consent.spec.ts	New. 6 browser tests.
web/e2e/global-setup.ts	New. Section 5, plus restoring the legal baseline so local reruns are deterministic.
3 existing e2e specs	Signing up now includes the consent step.
core/auth/flow.test.ts · catalog.test.ts · gate.test.ts	Helpers carry the acceptance. See below.
i18n fr.json · en.json	7 keys per locale.
Second commit – the CI fix	
web/lib/auth.ts	The defect: the auth instance is finally given a policy resolver, so platform_settings governs at runtime.
core/auth/better-auth.ts	Policy resolved per request; Better Auth's backstop derived from the same policy instead of a literal.
core/auth/phone-otp-plugin.ts	The ten-a-minute rule removed; lifetime and attempt bound taken from the resolved policy.
core/ratelimit/index.ts	OtpPolicySource and resolveOtpPolicy — a policy may now be a value or something that fetches one.
core/auth/phone-otp.test.ts	3 tests for the wiring, including one that changes a limit after the instance exists.
core/test/harness.ts	Restores the policy row between tests — several tests change it, which is the only honest way to test that it is configuration.
web/e2e/otp-policy.spec.ts	New. 2 browser tests that ask the running server, over HTTP, to honour a stored limit.

FILE	WHY
web/playwright.config.ts	<code>NODE_ENV=production</code> , so a local run and a CI run are the same run.

WHY THREE EXISTING TEST FILES CHANGED

The precondition genuinely moved: a new account is no longer usable on creation. Their helpers now accept the general terms, rather than the gate being softened to suit them. One is worth noting specifically — `gate.test.ts` 's "unconsented seller" now accepts the *account* terms deliberately, so its refusals stay attributable to `seller_terms` . Without that the file would have proved the seller gate exists while actually exercising a different one.

No new dependency; `pnpm-lock.yaml` is untouched. The ledger, money model, scoped RBAC, catalogue visibility rules and the browser-CI foundation have no diff.

ITEM	STATE
The documents still have no text. Every version is <code>0.0.0-placeholder</code> . People are now required to accept documents that say nothing — the mechanism is real, the content is not.	BLOCKS REAL USE
Consent cannot be withdrawn. Records are append-only and there is no revocation path. Under data-protection law that is a real gap, and it is now more visible because everyone has records.	UNRESOLVED
Existing accounts were not migrated. Anyone created before this commit is <code>active</code> with no account consents. The re-accept gate catches them at <code>createStore</code> ; nothing else asks.	NEEDS A DECISION
The re-accept gate is only on <code>createStore</code> . An active account whose terms changed can still read its wallet.	DELIBERATE; WIDEN WHEN THERE ARE MORE ACTIONS
The transport backstop is now twice the hourly allowance per minute. That ratio is my judgement, not a reviewed number: it is set so the audited PostgreSQL refusal is always the one a caller meets. Section 5. A decision I would like confirmed.	NEEDS A DECISION
The per-IP OTP ceiling is still the number to tune before launch — carrier NAT in Niger puts many subscribers behind one address. It is now genuinely tunable without a deploy, which it was not before this commit.	WATCH
Nothing else asserts that a control declared in <code>packages/core</code> is actually reachable from the application. The policy wiring is covered now; the same class of gap could exist elsewhere, and only an end-to-end test would show it.	OPEN
No admin screen publishes a document version; it remains an SQL insert.	ACCEPTED FOR NOW

The third row is the one I would settle next, and it is a one-line decision: leave existing accounts alone, or mark them `pending_consent` so they are prompted on next use. There are no production accounts yet, so the cost is zero today and rises from here.

THE DECISION I ACTUALLY NEED FROM YOU

Better Auth's in-memory limiter and our PostgreSQL one both guard the same endpoint. I have made the first strictly looser than the second, so it bounds a flood without ever pre-empting the configured policy, and so the refusal a caller meets is the audited one. The alternative readings are *tighter* (accept that a burst is refused unaudited, in a shape that does not match the rest of the API) or *removed entirely* (rely on PostgreSQL alone, which is authoritative and multi-instance but does one round trip per refused request). I chose the middle. It is a rate-limiting parameter on an unauthenticated endpoint, so I would rather you agreed than assumed.

Proposed next: checkout against the mock provider, per your milestone plan. **Not started.**

Phase 2 · signup consent · branch `claude/create-app-repository-1cxsih` · head `e3ded66`